

Security Assessment Report

Prepared for <https://fintrack-finance.lovable.app/>

Scanned: 2026-05-16 17:00:23 Duration: 32.83s

Critical Risk • Score 100

Scan Overview

TARGET

<https://fintrack-finance.lovable.app/>

HTTPS ENABLED

Yes

TLS GRADE

A+

HEADER SCORE

46.7%

Overview of Security Assessment

We conducted a comprehensive security assessment of your website, `fintrack-finance.lovable.app`. Our evaluation revealed a total of 31 distinct security issues, categorized by severity into critical, high, medium, low, and secure. The overall risk level is considered critical, with a security headers score of 46.7%, indicating that some important security measures are either missing or inadequate.

Security Headers Explanation

Security headers are pieces of information sent by your web server that instruct the browser on how to behave when handling the content of your site. A higher score in security headers indicates better protection against various types of attacks, such as cross-site scripting (XSS) and clickjacking. A score of 46.7% indicates that some essential security measures, such as the Content-Security-Policy and X-Frame-Options, are not properly configured.

Critical Findings

Missing Content-Security-Policy

What we tested: We checked for the Content-Security-Policy header.

What we found: The header is missing on your website.

Vulnerability: This indicates a high risk for Cross-Site Scripting (XSS) attacks.

Exploitation: An attacker could inject malicious scripts that steal session cookies or redirect users.

Mitigation: Add the following line to your server configuration: `Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'; base-uri 'self'`.

Exposed Spring Actuator Env

What we tested: We checked the accessibility of the path '/actuator/env'.

What we found: This path is publicly accessible.

Vulnerability: This exposes sensitive environment information.

Exploitation: An attacker could extract database passwords and API keys.

Mitigation: Block access to this path or remove it if unnecessary.

Critical Exposed JBoss JMX Console

What we tested: We checked the accessibility of the path '/jmx-console'.

What we found: This path is publicly accessible.

Vulnerability: Exposure of console access can lead to data leakage.

Exploitation: An attacker could download sensitive data and source code.

Mitigation: Block access to this path via server configuration.

High Severity Findings

Exposed Git Repository and Config

What we tested: We checked accessibility of the paths '/.git/HEAD' and '/.git/config'.

What we found: Both paths are publicly accessible.

Vulnerability: This can leak sensitive credentials and configuration.

Exploitation: An attacker can access your source code and potential passwords.

Mitigation: Block access to these paths or remove unnecessary files.

Exposed phpMyAdmin

What we tested: We checked accessibility for the paths '/phpmyadmin' and '/pma'.

What we found: These paths are publicly accessible.

Vulnerability: This could expose administrative configurations.

Exploitation: An attacker could gain access to your database.

Mitigation: Block access to these paths via your server configuration.

Medium Severity Findings

Missing X-Frame-Options

What we tested: We checked for the X-Frame-Options header.

What we found: The header is missing.

Vulnerability: This increases the risk of clickjacking.

Exploitation: An attacker can embed your site in an iframe, misleading users.

Mitigation: Add this to your server config: X-Frame-Options: DENY.

Exposed Admin and Other Sensitive Endpoints

What we tested: We checked accessibility of several sensitive endpoints, including '/admin/', '/wp-admin', '/debug', and similar paths.

What we found: Many are publicly accessible, putting your website at risk.

Vulnerability: These can lead to unauthorized access to sensitive functionalities or data.

Exploitation: An attacker can manipulate site settings or extract data.

Mitigation: Block access to these paths or ensure they are well-protected.

Potential DOM Cross-Site Scripting (XSS) Sink Detected

What we tested: We scanned for unsafe DOM practices in JavaScript.

What we found: Dangerous patterns were detected.

Vulnerability: This can allow XSS attacks.

Exploitation: An attacker can control data, causing unwanted script execution.

Mitigation: Avoid using dangerous sinks and sanitize user inputs.

Mixed Content Issues

What we tested: We scanned for HTTP resource references on an HTTPS page.

What we found: Mixed content was detected.

Vulnerability: This undermines the encryption benefits of HTTPS.

Exploitation: An attacker could inject malicious scripts through unencrypted content.

Mitigation: Ensure all resources are loaded via HTTPS.

Summary of Priorities and Next Steps

Due to the critical nature of the findings, specific actions should be prioritized to protect your website:

1. Implement the missing Content-Security-Policy and X-Frame-Options headers.
2. Block access to all exposed sensitive paths and remove any unnecessary files.
3. Regularly review all publicly accessible endpoints and ensure they are secure.
4. Address potential XSS vulnerabilities and mixed content issues by sanitizing input and enforcing HTTPS for all resources.

Conducting these steps will significantly reduce your website's vulnerability and enhance its overall security posture. Regular

security audits should also be considered to maintain a strong defense against evolving threats.

Security Posture Details

Present: Strict-Transport-Security, X-Content-Type-Options, Referrer-Policy

Missing: Content-Security-Policy, X-Frame-Options

Server

Server: cloudflare

Domain Discovery

Discovered 1 page(s); checked 1 for security headers.

- <https://fintrack-finance.lovable.app/>

Detailed Issues

SEVERITY	NAME	DESCRIPTION	WHAT WE TESTED	THIS INDICATES	KEY INDICATOR	HOW EXPLOITED	REMEDIATION
----------	------	-------------	----------------	----------------	---------------	---------------	-------------

critical	Missing Content-Security-Policy	CSP - Prevents Cross-Site Scripting (XSS) and data injection	We checked for the Content-Security-Policy (CSP) header.	Without CSP, any injected script (via Cross-Site Scripting (XSS)) will execute without restriction.	Testing We checked for the Content-Security-Policy (CSP) header indicates Without CSP, any injected script (via Cross-Site Scripting (XSS)) will execute without restriction.	An injected script can steal session cookies, log keystrokes, or redirect users to phishing pages.	Add this to your server config: Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'; base-uri 'self'
medium	Missing X-Frame-Options	Clickjacking protection	We checked for the X-Frame-Options header.	Without this header, your page can be embedded in an invisible iframe on another site.	Testing We checked for the X-Frame-Options header indicates Without this header, your page can be embedded in an invisible iframe on another site.	An attacker overlays an invisible version of your page on a malicious site, tricking users into clicking buttons they can't see (clickjacking).	Add this to your server config: X-Frame-Options: DENY
high	Exposed Git Repository	The file or path '/.git/HEAD' is publicly accessible and should not be	We requested the path '/.git/HEAD' to check if it is publicly accessible.	Exposed Git Repository can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/.git/HEAD' to check if it is publicly accessible indicates Exposed Git Repository can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/.git/HEAD' via your server/firewall config, or delete the file if it shouldn't exist.

high	Exposed Git Config	The file or path <code>/.git/config</code> is publicly accessible and should not be	We requested the path <code>/.git/config</code> to check if it is publicly accessible.	Exposed Git Config can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path <code>/.git/config</code> to check if it is publicly accessible indicates Exposed Git Config can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to <code>/.git/config</code> via your server/firewall config, or delete the file if it shouldn't exist.
medium	Exposed Admin Panel	The file or path <code>/admin/</code> is publicly accessible and should not be	We requested the path <code>/admin/</code> to check if it is publicly accessible.	Exposed Admin Panel can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path <code>/admin/</code> to check if it is publicly accessible indicates Exposed Admin Panel can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to <code>/admin/</code> via your server/firewall config, or delete the file if it shouldn't exist.
medium	Exposed Admin Panel	The file or path <code>/administrator</code> is publicly accessible and should not be	We requested the path <code>/administrator</code> to check if it is publicly accessible.	Exposed Admin Panel can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path <code>/administrator</code> to check if it is publicly accessible indicates Exposed Admin Panel can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to <code>/administrator</code> via your server/firewall config, or delete the file if it shouldn't exist.

high	Exposed phpMyAdmin	The file or path '/phpmyadmin' is publicly accessible and should not be	We requested the path '/phpmyadmin' to check if it is publicly accessible.	Exposed phpMyAdmin can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/phpmyadmin' to check if it is publicly accessible indicates Exposed phpMyAdmin can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/phpmyadmin' via your server/firewall config, or delete the file if it shouldn't exist.
medium	Exposed Admin Panel	The file or path '/admin' is publicly accessible and should not be	We requested the path '/admin' to check if it is publicly accessible.	Exposed Admin Panel can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/admin' to check if it is publicly accessible indicates Exposed Admin Panel can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/admin' via your server/firewall config, or delete the file if it shouldn't exist.

high	Exposed phpMyAdmin	The file or path '/phpmyadmin/' is publicly accessible and should not be	We requested the path '/phpmyadmin/' to check if it is publicly accessible.	Exposed phpMyAdmin can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/phpmyadmin/' to check if it is publicly accessible indicates Exposed phpMyAdmin can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/phpmyadmin/' via your server/firewall config, or delete the file if it shouldn't exist.
high	Exposed phpMyAdmin (pma)	The file or path '/pma' is publicly accessible and should not be	We requested the path '/pma' to check if it is publicly accessible.	Exposed phpMyAdmin (pma) can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/pma' to check if it is publicly accessible indicates Exposed phpMyAdmin (pma) can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/pma' via your server/firewall config, or delete the file if it shouldn't exist.

medium	Exposed WordPress Admin	The file or path '/wp-admin' is publicly accessible and should not be	We requested the path '/wp-admin' to check if it is publicly accessible.	Exposed WordPress Admin can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/wp-admin' to check if it is publicly accessible indicates Exposed WordPress Admin can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/wp-admin' via your server/firewall config, or delete the file if it shouldn't exist.
medium	Exposed Apache Server Status	The file or path '/server-status' is publicly accessible and should not be	We requested the path '/server-status' to check if it is publicly accessible.	Exposed Apache Server Status can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/server-status' to check if it is publicly accessible indicates Exposed Apache Server Status can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/server-status' via your server/firewall config, or delete the file if it shouldn't exist.

medium	Exposed Apache Server Info	The file or path '/server-info' is publicly accessible and should not be	We requested the path '/server-info' to check if it is publicly accessible.	Exposed Apache Server Info can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/server-info' to check if it is publicly accessible indicates Exposed Apache Server Info can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/server-info' via your server/firewall config, or delete the file if it shouldn't exist.
medium	Exposed Nginx Status Page	The file or path '/nginx_status' is publicly accessible and should not be	We requested the path '/nginx_status' to check if it is publicly accessible.	Exposed Nginx Status Page can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/nginx_status' to check if it is publicly accessible indicates Exposed Nginx Status Page can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/nginx_status' via your server/firewall config, or delete the file if it shouldn't exist.

high	Exposed Spring Boot Actuator	The file or path '/actuator' is publicly accessible and should not be	We requested the path '/actuator' to check if it is publicly accessible.	Exposed Spring Boot Actuator can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/actuator' to check if it is publicly accessible indicates Exposed Spring Boot Actuator can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/actuator' via your server/firewall config, or delete the file if it shouldn't exist.
critical	Exposed Spring Actuator Env	The file or path '/actuator/env' is publicly accessible and should not be	We requested the path '/actuator/env' to check if it is publicly accessible.	Exposed Spring Actuator Env can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/actuator/env' to check if it is publicly accessible indicates Exposed Spring Actuator Env can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/actuator/env' via your server/firewall config, or delete the file if it shouldn't exist.

low	Exposed Spring Actuator Health	The file or path '/actuator/health' is publicly accessible and should not be	We requested the path '/actuator/health' to check if it is publicly accessible.	Exposed Spring Actuator Health can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/actuator/health' to check if it is publicly accessible indicates Exposed Spring Actuator Health can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/actuator/health' via your server/firewall config, or delete the file if it shouldn't exist.
low	Exposed Swagger UI	The file or path '/api/swagger-ui' is publicly accessible and should not be	We requested the path '/api/swagger-ui' to check if it is publicly accessible.	Exposed Swagger UI can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/api/swagger-ui' to check if it is publicly accessible indicates Exposed Swagger UI can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/api/swagger-ui' via your server/firewall config, or delete the file if it shouldn't exist.

low	Exposed Application Programming Interface (API) Docs	The file or path '/api-docs' is publicly accessible and should not be	We requested the path '/api-docs' to check if it is publicly accessible.	Exposed Application Programming Interface (API) Docs can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/api-docs' to check if it is publicly accessible indicates Exposed Application Programming Interface (API) Docs can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/api-docs' via your server/firewall config, or delete the file if it shouldn't exist.
medium	Exposed GraphQL Endpoint	The file or path '/graphql' is publicly accessible and should not be	We requested the path '/graphql' to check if it is publicly accessible.	Exposed GraphQL Endpoint can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/graphql' to check if it is publicly accessible indicates Exposed GraphQL Endpoint can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/graphql' via your server/firewall config, or delete the file if it shouldn't exist.

high	Exposed Web Console	The file or path '/console' is publicly accessible and should not be	We requested the path '/console' to check if it is publicly accessible.	Exposed Web Console can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/console' to check if it is publicly accessible indicates Exposed Web Console can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/console' via your server/firewall config, or delete the file if it shouldn't exist.
high	Exposed Solr Admin UI	The file or path '/solr' is publicly accessible and should not be	We requested the path '/solr' to check if it is publicly accessible.	Exposed Solr Admin UI can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/solr' to check if it is publicly accessible indicates Exposed Solr Admin UI can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/solr' via your server/firewall config, or delete the file if it shouldn't exist.
critical	Exposed JBoss JMX Console	The file or path '/jmx-console' is publicly accessible and should not be	We requested the path '/jmx-console' to check if it is publicly accessible.	Exposed JBoss JMX Console can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/jmx-console' to check if it is publicly accessible indicates Exposed JBoss JMX Console can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/jmx-console' via your server/firewall config, or delete the file if it shouldn't exist.

high	Exposed JBoss Web Console	The file or path '/web-console' is publicly accessible and should not be	We requested the path '/web-console' to check if it is publicly accessible.	Exposed JBoss Web Console can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/web-console' to check if it is publicly accessible indicates Exposed JBoss Web Console can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/web-console' via your server/firewall config, or delete the file if it shouldn't exist.
medium	Exposed Debug Endpoint	The file or path '/debug' is publicly accessible and should not be	We requested the path '/debug' to check if it is publicly accessible.	Exposed Debug Endpoint can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/debug' to check if it is publicly accessible indicates Exposed Debug Endpoint can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/debug' via your server/firewall config, or delete the file if it shouldn't exist.

medium	Exposed Django Debug Toolbar	The file or path '/_debug_toolbar' is publicly accessible and should not be	We requested the path '/_debug_toolbar' to check if it is publicly accessible.	Exposed Django Debug Toolbar can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/_debug_toolbar' to check if it is publicly accessible indicates Exposed Django Debug Toolbar can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/_debug_toolbar' via your server/firewall config, or delete the file if it shouldn't exist.
low	Exposed Trace Endpoint	The file or path '/trace' is publicly accessible and should not be	We requested the path '/trace' to check if it is publicly accessible.	Exposed Trace Endpoint can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/trace' to check if it is publicly accessible indicates Exposed Trace Endpoint can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/trace' via your server/firewall config, or delete the file if it shouldn't exist.

high	Exposed Backup Directory	The file or path '/backup' is publicly accessible and should not be	We requested the path '/backup' to check if it is publicly accessible.	Exposed Backup Directory can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/backup' to check if it is publicly accessible indicates Exposed Backup Directory can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/backup' via your server/firewall config, or delete the file if it shouldn't exist.
low	Exposed Dockerfile	The file or path '/Dockerfile' is publicly accessible and should not be	We requested the path '/Dockerfile' to check if it is publicly accessible.	Exposed Dockerfile can leak credentials, source code, configuration, or sensitive data.	Testing We requested the path '/Dockerfile' to check if it is publicly accessible indicates Exposed Dockerfile can leak credentials, source code, configuration, or sensitive data.	An attacker downloads the file and extracts database passwords, Application Programming Interface (API) keys, or source code.	Block access to '/Dockerfile' via your server/firewall config, or delete the file if it shouldn't exist.

medium	Potential DOM Cross-Site Scripting (XSS) Sink Detected	Page uses JavaScript patterns that can lead to DOM Cross-Site Scripting (XSS): setTimeout(	We scanned the page JavaScript for dangerous DOM manipulation patterns.	If any of these sinks receive user-controlled data (URL params, hash, postMessage), Cross-Site Scripting (XSS) is possible.	Testing We scanned the page JavaScript for dangerous DOM manipulation patterns indicates If any of these sinks receive user-controlled data (URL params, hash, postMessage), Cross-Site Scripting (XSS) is possible.	Attacker controls data that flows into a dangerous sink via the URL or other client-side input, causing script execution.	Avoid using dangerous sinks with user-controlled data. Use <code>textContent</code> instead of <code>innerHTML</code> . Sanitize inputs with <code>DOMPurify</code> if HTML is required.
medium	Mixed Content (HTTP Resources on Hypertext Transfer Protocol Secure (HTTPS) Page)	Hypertext Transfer Protocol Secure (HTTPS) page loads 1 resource(s) over plain Hypertext Transfer Protocol (HTTP)	We scanned the page HTML for Hypertext Transfer Protocol (HTTP) resource references on an Hypertext Transfer Protocol Secure (HTTPS) page.	Mixed content means parts of the page are unencrypted, undermining Hypertext Transfer Protocol Secure (HTTPS) protection.	Testing We scanned the page HTML for Hypertext Transfer Protocol (HTTP) resource references on an Hypertext Transfer Protocol Secure (HTTPS) page indicates Mixed content means parts of the page are unencrypted, underm...	An attacker can modify the Hypertext Transfer Protocol (HTTP) resource in transit to inject malicious JavaScript even though the main page is Hypertext Transfer Protocol Secure (HTTPS).	Change all resource URLs to Hypertext Transfer Protocol Secure (HTTPS) or use protocol-relative URLs (<code>//example.com/script.js</code>).